Figure 25.7 An example JWT, decoded using the website https://jwt.io. The JWT consists of three parts: the header, the payload, and the signature. You must always verify the signature of any JWTs you receive.

WARNING Always validate the signature of any JWTs you consume, as described in the JWT Best Current Practices RFC (https://www.rfc-editor.org/rfc/rfc8725). ASP.NET Core does this by default.

Figure 25.7 shows the claims included in the JWT, some of which have cryptic names like `iss` and `iat`. These are standard claim names used in OpenID Connect (standing for "Issuer" and "Issued at," respectively). You generally don't need to worry about these, as they're automatically handled by ASP.NET Core when it decodes the token. Nevertheless, it's helpful to understand what some of these claims mean, as it will help when things go wrong:

- `sub`—The *subject* of the token, the unique identifier of the subject it's describing. This will often be a user, in which case it may be the identity provider's unique ID for the user.
- `aud`—The *audience* of the token, specifying the domains for which this token was created. When an API validates the token, the API should confirm that the JWT's `aud` claim contains the domain of the API.